INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 4 Lab Assignment: Applied Compliance Frameworks & Research

Student Name: Joy Orilade
Date: 9th Feb, 2026
Instructor: Com Idris Aminu

TASK 1: NIST Cybersecurity Framework (CSF) Deep Dive

Write a Research Summary

1. **In your own words, write a summary of the NIST CSF 2.0.**

   Answer:

NIST CSF 2.0 is a voluntary framework that help organization, regardless of their size, maturity, and sector (government, industry, academia, nonprofit etc) to reduce or improve their cybersecurity posture. The Framework is not a one-size-fits-all approach to managing cybersecurity risks. It can be used by organizations to understand, assess, prioritize, and communicate cybersecurity risks; it is particularly useful for fostering internal and external communication across teams as well as integrating with broader risk management strategies

CSF 2.0 can be used by organizations to understand, assess, prioritize, and communicate cybersecurity risks; it is particularly useful for fostering internal and external communication across teams — as well as integrating with broader risk management strategies. The CSF will be used to address cybersecurity risks alongside other risks of the enterprise, including those that are financial, privacy, supply chain, reputational, technological, or physical in nature

The CSF describes desired outcomes that are intended to be understood by a broad audience, including executives, managers, and practitioners, regardless of their cybersecurity expertise. Because these outcomes are sector-, country-, and technology-neutral, they provide an organization with the flexibility needed to address their unique risks, technologies, and mission considerations.

2. **Explain the purpose of the framework and its importance in the cybersecurity landscape.**

   Answer

NIST CSF 2.0 was recently updated from from CSF 1.0 - CSF 2.0 where the function Govern was included as a function which make the total number of the function to be 6 .

It include the following components

1. CSF Core: it is the taxonomy of cybersecurity outcomes that help organization manage or improved risks. CSF Core has componenet which are the Function(Govern, Identify, Protect, Detect, Respond and Recover), Categories and Sub-categories.

2. CSF Organizational Profile: it is used in describing an organization's current and target cybersecurity posture in terms of the CSF Core's outcomes. Organizational Profiles are used to understand, tailor, assess, and prioritize cybersecurity outcomes based on an organization's mission objectives, stakeholder expectations, threat landscape, and requirements.

   Organizational Profiles can be categorized as:

• A ***Current Profile*** that specifies the CSF outcomes an organization is currently achieving and characterizes how or to what extent each outcome is being achieved.

• A ***Target Profile*** that specifies the desired CSF outcomes an organization has selected and prioritized for achieving its cybersecurity risk management objectives.

3. CSF Tiers: can be applied to CSF Organizational Profiles to characterize the rigor of an organization's cybersecurity risk governance and management outcomes. This can help provide context on how an organization views cybersecurity risks and the processes in place to manage those risks. The Tiers can also be valuable when reviewing processes and practices to determine needed improvements and monitor progress made through those improvements.

The Tiers capture an organization's outcomes over a range:

• Tier 1 - Partial

• Tier 2 - Risk Informed

• Tier 3 - Repeatable

• Tier 4 - Adaptive.

They reflect a progression from informal, ad hoc responses to approaches that are agile, risk-informed, and continuously improving.

Importance

• Prioritize: Identify, organize, and prioritize actions for managing cybersecurity risks that align with the organization's mission, legal and regulatory requirements, and risk management and governance expectations.

• Communicate: Provide a common language for communicating inside and outside the organization about cybersecurity risks, capabilities, needs, and expectations.

• It help organization to assess their current cybersecurity posture

• Determine gaps, and assess progress toward addressing those gaps.

• The CSF is a flexible framework that is intended to be tailored for use by all organizations regardless of size. Organizations will continue to have unique risks — including different threats and vulnerabilities — and risk tolerances, as well as unique mission objectives and requirements.

• Establish the desired cybersecurity posture based on business objectives and risk tolerance.

3. Describe each of the six core functions and their roles.

IMG_256

IMG_256

Function

1. **Govern (GV):** The Govern Function helps establish and monitor organizational business's cybersecurity risk management strategy, expectations, and policy. The Govern Function provides outcomes to inform what an organization may do to achieve and prioritize the outcomes of the other five Functions in the context of its mission and stakeholder expectations.

Govern(GV) category and categories identifier addresses an understanding of;

• Organizational Context - GV.OC

• Risk Management Strategy - GV.RM

• Roles, Responsibilities, and Authorities - GV.RR

• Policy - GV.PO

• Oversight - GV.OV

• Cybersecurity Supply Chain Risk Management - GV.SC

2. **Identify (ID):** it help the organization understand the current cybersecurity risks to the business, what assets the business relies upon by creating and maintaining an inventory of hardware, software, systems, and services, Assess the effectiveness of the business's cybersecurity program to identify areas that need improvement, prioritize documenting internal and external cybersecurity threats and associated responses using a risk register, and Communicate to staff the importance of identifying needed improvements to cybersecurity risk management processes, procedures, and activities

   Identify (ID) category and categories identifier are;

• Asset management (ID.AM)

• Risk Assessment (ID.RA)

• Improvement (ID.IM)

3. **Protect (PR):** It supports ability to use safeguards to prevent or reduce cybersecurity risks. It help organization to understand what information employees should or do have access to. Restrict sensitive information access to only those employees who need it to do their jobs. Also, assess the timeliness, quality, and frequency of your company's cybersecurity training for employees, prioritize requiring multi-factor authentication on all accounts that offer it and consider using password managers to help staff generate and protect strong passwords, prioritize changing default manufacturer passwords, and Communicate to staff how to recognize common attacks, report attacks or suspicious activity, and perform basic cyber hygiene tasks.

Protect (PR) category and categories identifier are;

• Identity Management, Authentication and Access Control (PR.AA)

• Awareness and Training (PR.AT)

• Data Security (PR.DS)

• Platform Security (PR.PS)

• Technology Infrastructure Resilience (PR.IR)

4. **Detect (DE):** It provides outcomes that help organization find and analyze possible cybersecurity attacks and compromises. It help organization understand how to identify common indicators of a cybersecurity incident. Also, prioritize installing and maintaining antivirus and anti-malware software on all business devices including servers, desktops and laptops, prioritize engaging a service provider to monitor computers and networks for suspicious activity if you don't have the resources to do it internally, and Communicate with your authorized incident responder, such as an MSSP, about the relevant details from the incident to help them analyze and mitigate it

Detect (DE) category and catergories identifiers are;

• Continuous Monitoring (DE.CM)

• Adverse Event Analysis (DE.AE)

5. **Respond (RS):** it provide supports your ability to take action regarding a detected cybersecurity incident.

It help organization understand what your incident response plan is and who has authority and

responsibility for implementing various aspects of the plan, assess the incident to determine its severity, what happened, and its root cause, prioritize taking steps to contain and eradicate the incident to prevent further damages, and communicate a confirmed

cybersecurity incident with all internal and external stakeholders (e.g., customers, business partners, law enforcement agencies,

regulatory bodies) as required by laws, regulations, contracts, or policies.

Respond (RS) category and categories identifiers are;

• Incident Management (RS.MA)

• Incident Analysis (RS.AN)

• Incident Response Reporting and Communication (RS.CO)

• Incident Mitigation (RS.MI)

6. **Recover (RC):** It involves activities to restore assets and operations that were impacted by a cybersecurity incident. It help organization understand who within and outside your business has recovery responsibilities, assess what happened by preparing an after-action report on your own or in

consultation with a vendor/partner—that documents the incident, the response and recovery actions taken, and lessons learned, prioritize your recovery actions based on organizational needs, resources, and asset impacted and communicate and document completion of the incident and resumption of normal activities.

Recover (RC) categories and categories identifier are;

• Incident Recovery Plan Execution (RC.RP)

• Incident Recovery Communication (RC.CO)

Step 3: Apply to SecureHealth

Scenario: SecureHealth

SecureHealth is a regional healthcare provider with three clinics. They have a small IT team and have recently experienced a minor data breach. They want to adopt a cybersecurity framework to mature their security program and protect patient data more effectively. They have a limited budget and need a flexible, risk-based approach.

Create a high-level plan for how SecureHealth could use the NIST CSF 2.0 to improve its cybersecurity posture.

High-level plan

Phase 1 - Establish Governance for SecureHealth: SecureHealth need to understand how cybersecurity risks can disrupt achievement of your business's mission. The Govern function allow oversight thereby assigning roles and responsibilities of the IT team.

• Understand and assess specific cybersecurity needs: Determine your organization's unique risks and needs. Discuss the current and predicted risk environment and the amount of risk SecureHealth is willing to accept.

• Develop a tailored cybersecurity risk strategy. This should be based on your organization's specific cybersecurity objectives, the risk environment, and lessons learned from the past.

• Establish defined risk management policies. Policies should be approved by management and should be organization-wide, repeatable, and recurring, and should align with the current cybersecurity threat environment, risks (which will change over time), and mission objectives.

Phase 2 - Identify What Needs Protection: create inventory of patient data systems, computers and medical devices and network equipment.

• Identify critical business processes and assets: Consider which of SecureHealth's activities absolutely must continue to be viable (e.g., patient databases, clinic networks) across the three locations

• Maintain inventories of hardware, software, services, and systems: Know what computers and software SecureHealth uses including services provided by suppliers because these are frequently the entry points of malicious actors. This inventory could be as simple as a spreadsheet. Consider including owned, leased, and employees' personal devices and apps.

• Document information flows: Consider what type of information SecureHealth collects and uses (and where the data are located and how they are used), especially when contracts and external partners are involved.

• Identify threats, vulnerabilities, and risk to assets: Informed by knowledge of internal and external threats, risks should be identified, assessed, and documented. Examples of ways to document them include risk registers – repositories of risk information, including data about risks over time. Ensure risk responses are identified, prioritized, and executed, and that results are monitored.

• Lessons learned are used to identify improvements: When conducting day-to-day business operations, it is important to identify ways to further refine or enhance performance, including opportunities to better manage and reduce cybersecurity risks.

Phase 3: Strengthen Basic Protections: With limited budget, SecureHealth should focus on low-cost, high-impact security controls.

• Manage access: Create unique accounts for employees and ensure users only have access to necessary resources. Authenticate users before they are granted access to information, computers, and applications. Manage and track physical access to facilities/devices.

• Train users: Regularly train employees of SecureHealth to ensure they are aware of cybersecurity policies and procedures and that they have the knowledge and skills to perform general and specific tasks; explain how to recognize common attacks and report suspicious activity.

• Protect and monitor your devices: Consider using endpoint security products. Apply uniform configurations to devices and control changes to device configurations. Disable

services or features that don't support mission functions. Ensure devices are disposed of securely.

• Protect sensitive data: Ensure sensitive stored or transmitted data are protected by encryption. Consider utilizing integrity checking so only approved changes are made to data. Securely delete and/or destroy data when no longer needed or required.

• Manage and maintain software. Regularly update operating systems and applications; enable automatic updates. Replace end-of-life software with supported versions. Consider using software tools to scan devices for additional vulnerabilities and remediate them.

• Conduct regular backups. Back up data at agreed-upon schedules or use built-in backup capabilities; software and cloud solutions can automate this process. Keep at least one frequently backed-up set of data offline to protect it against ransomware. Test to ensure that backed-up data can be successfully restored to systems.

Phase 4 - Improve Monitoring Capabilities: SecureHealth needs the ability to notice problems early

• Monitor networks, systems, and facilities continuously to find potentially adverse events: Develop and test processes and procedures for detecting indicators of a cybersecurity incident on the network and in the physical environment. Collect log information from multiple organizational sources to assist in detecting unauthorized activity.

• Determine and analyze the estimated impact and scope of adverse events: If a cybersecurity event is detected, SecureHealth should work quickly and thoroughly to understand the impact of the incident. Understanding details regarding any cybersecurity incidents will help inform the response.

• Provide information on adverse events to authorized staff and tools: When adverse events are detected, provide information about the event internally to authorized personnel to ensure appropriate incident response actions are taken.

Phase 5 - Build an Incident Response Process: Since SecureHealth has already experienced a breach, response planning is critical.

• Execute an incident response plan once an incident is declared, in coordination with relevant third parties: To properly execute an incident response plan, ensure everyone knows their responsibilities; this includes understanding any requirements (e.g., regulatory, legal reporting, and information sharing).

• Categorize and prioritize incidents and escalate or elevate as needed: Analyze what has been taking place, determine the root cause of the incident, and prioritize which incidents require attention first. Communicate this prioritization to your team and ensure everyone understands who information should be communicated to regarding a prioritized incident when it occurs.

• Collect incident data and preserve its integrity and provenance: Collecting information in a safe manner will help in SecureHealth’s response to an incident. Ensure that data are still

secure after the incident to maintain SecureHealth's reputation and trust from stakeholders.

• Notify internal and external stakeholders of any incidents and share incident information with them — following policies set by SecureHealth which should be with 72 hours of the incident: Securely share information consistent with response plans and information-sharing agreements. Notify business partners and customers of incidents in accordance with contractual requirements.

• Contain and eradicate incidents. Executing a developed and tested response plan will help SecureHealth contain the effects of an incident and eradicate it.

Phase 6 - Plan for Recovery: SecureHealth must be able to return to normal operations after an incident.

• Understand roles and responsibilities: Understand who, within and outside your business, has recovery responsibilities. Know who has access and authority to make decisions to carry out your response efforts on behalf of the business.

• Execute your recovery plan: Ensure operational availability of affected systems and services; and prioritize and perform recovery tasks.

• Double-check your work: It is important to ensure the integrity of backups and other recovery assets before using them to resume regular business operations.

• Communicate with internal and external stakeholders: Carefully account for what, how, and when information will be shared with various stakeholders so that all interested parties receive the information they need, but no inappropriate information is shared. Communicate to the staff any lessons learned and revisions to processes, procedures, and technologies (following policies already set by SecureHealth). This is a good time to train, or retrain, staff on cybersecurity best practices.

Task 2: ISO 27001 Control Implementation Analysis

Scenario

You are a security consultant hired by a mid-sized e-commerce company. They want to improve their security posture and are considering ISO 27001 certification. Your task is to help them understand a specific set of controls.

Step 1: Research ISO 27001:2022

Research the ISO 27001:2022 standard, focusing on the controls listed in Annex A. Use the resources provided in the appendix of this document.

Step 2: Select a Control Family

1. Choose **one** of the following control families from Annex A to focus on:

   A.6: People controls: People controls enable businesses to regulate the human component of their information security program, by defining the manner in which personnel interact with data and each other. These controls cover secure human resources management, personnel security, and awareness and training.

   • Number of contol: 8

   • Contol numbers:ISO 27001 Annex A 6.1 to 6.8

Step 3: Create an Implementation Guide

1. For your selected control family, write a detailed implementation guide.

The People control: This control describes 8 controls related to secure management of human resources:

2. **Explain the purpose of the controls in that family.**

Answer

The people control This group of 8 controls addresses the human element of information security. They are designed to ensure that people are a strong line of defense, not a weak link.

3. **Provide practical, step-by-step instructions on how an organization could implement them.**

Answer

Control 6.1 - Screening control

ISO 27001 control A.6.1 Screening requires companies to conduct background checks of employees and third-party personnel on an ongoing basis in accordance with applicable laws and regulations, in order to employ only trusted people.

Implementation

In order to comply with control A.6.1 Screening, organization might implement the following:

• Technology — the technology to enable the background check of job candidates, or external suppliers, may include Internet access to social networks, professional associations, and legal authorities, within the applicable legal limits.

• Organization/processes — you should set up a process for defining who is in charge of performing background checks, for which jobs, and in which circumstances. You can document those processes through a Screening Procedure or a Supplier Security Policy

• People — make employees aware of why performing background checks is needed, and train employees on how and when to perform them.

Control 6.2 - Terms and conditions of employment control

ISO 27001 control A.6.2 Terms and conditions of employment requires companies to include security clauses in their agreements with employees and third parties, in order for everyone to know exactly what is expected of them with regard to security

Implementation

In order to comply with control A.6.2 Terms and conditions of employment you might implement the following:

• Technology — companies of all sizes may use existing tools to handle documents to write and sign security clauses in agreements with employees and suppliers.

• Organization/processes — you should set up a process for defining which information security requirements must be included as terms and conditions of employment. You can document those processes by inserting security clauses into existing agreements with the personnel; alternatively, some additional documents can be signed, like a Statement of Acceptance of ISMS Documents, a confidentiality Statement, or NDAs.

• People — make employees aware of why security terms and conditions are needed, and train HR personnel on how to identify and include them in the company's documentation.

Control 6.3 - information security awareness, education and training: ISO 27001 control A.6.3 Information security awareness, education and training requires companies to explain to relevant people why security is needed, and how to comply with various security requirements. This is important in order to avoid people's resentment and noncompliance because of not knowing how to perform security activities.

Implementation: In order to comply with control A.6.3 Information security awareness, education and training organization should implement the following:

• Technology — the technology to enable information security awareness, education, and training may include software to develop the material, and access to Internet to share the material with employees and contractors. Small companies may simply use current office

applications, while bigger companies may use learning platforms to share material and assess and evaluate learning.

• Organization/processes — you should set up a process for defining which material must be developed, for whose audience, how often it must be presented, and how the effectiveness of the presentation is going to be measured. You can document those processes through a Training and awareness plan or a Training & Awareness Procedure.

• People — train HR personnel on how to develop and deliver security awareness and training.

Contol 6.4 - Disciplinary process: ISO 27001 control A.6.4 Disciplinary process requires companies to perform a formal disciplinary process against people who have performed a violation of information security rules, in order to establish whether such breach was intentional.

Implementation

In order to comply with control A.6.4 Disciplinary process you might implement the following:

• Technology — the technology to enable disciplinary processes may include forensic software to support the investigation of the most relevant incidents and hardware to securely store digital evidence. Small companies may use outsourced services when needed, while bigger companies may have a dedicated team and tools for such investigations.

• Organization/processes — you should set up a process for defining who must be involved in disciplinary processes, and the steps to be performed. You can document those processes through an incident management procedure or a Disciplinary Procedure.

• People — make employees aware of why performing disciplinary processes is needed, and train required personnel on how to perform them.

Control 6.5 - Responsibilities after termination or change of employment: ISO 27001 control A.6.5 Responsibilities after termination or change of employment requires companies to define which security duties will remain valid after a person leaves the company or changes the position within the company. This is done to avoid any unclear responsibilities after the change of a person's status. This can be done by including security clauses in the termination agreements or in annexes.

Implementation: In order to comply with control A.6.5 Responsibilities after termination or change of employment, you might implement the following:

• Technology — the technology to enforce the responsibilities after termination or change of employment may include access to systems and social media that enable monitoring (within legal restrictions) of ex-employees activities after employment.

• Organization/processes — you should set up a process for defining which information security requirements must be enforced after termination or change of employment. You

can document those processes by inserting security clauses into Confidentiality Statement, Termination Agreement, or similar documents.

• People — make employees aware of why defining responsibilities that need to be kept after termination or change of employment is needed, and train HR personnel on how to include them in proper documentation and make personnel aware of such requirements during the termination process.

Control 6.6 – Confidentiality or non-disclosure agreements: ISO 27001 control A.6.6 Confidentiality or non-disclosure agreements requires companies to define such agreements and sign them with all employees and relevant third parties, in order for everyone to know the requirements for protecting the information.

Implementation: In order to comply with control A.6.6 Confidentiality or non-disclosure agreements you might implement the following:

• Technology — the tools to write and sign confidentiality and non-disclosure agreements may be the same ones used to handle other documents.

• Organization/processes — you should set up a process for defining the criteria with whom to sign confidentiality and non-disclosure agreements, and what should be their content. You can then create templates for Confidentiality Statement or NDAs.

• People — make employees aware of why confidentiality statements and NDAs are needed and train HR personnel on how to develop them, and make personnel aware of such requirements.

Control 6.7 - Remote working: ISO 27001 control A.6.7 Remote working requires companies to define security rules when people are working from home or from other remote locations, in order to protect the information that is processed outside of the company's premises.

Implementation: In order to comply with control A.6.7 Remote working you might implement the following:

• Technology — the technology to enable remote working may include software (e.g., data loss prevention software, software for remote management, etc.), hardware (e.g., dedicated devices to be used remotely), and networks (e.g., VPN, dedicated links, etc.).

• Organization/processes — you should set up a process for defining criteria to allow remote work, minimum requirements for devices allowed to be used for remote work, who must authorize remote work, and what users can and can't do while working remotely. You can document those processes through Mobile Device and Remote Work Policy.

• People — make employees aware of the risks of working remotely, and train them on what they can and cannot do while teleworking.

Control 6.8 - Information security event reporting: ISO 27001 control A.6.8 Information security event reporting requires companies to enable people to report security events and incidents as quickly as possible, in order to prevent some larger damage.

Implementation: In order to comply with control A.6.8 Information security event reporting you might implement the following:

• Technology — the technology for event reporting could include software, hardware, networks, or communication. Smaller companies will probably be able to report events through phone calls, message applications, or other means of communication, whereas larger companies probably need some software that centralizes reports from all available channels and redirects them to the proper personnel to treat each one of them.

• Organization/processes — you should set up a process for identifying proper channels to report security events, to whom such reports need to be sent, and which information should be reported. You can document those processes through Incident Management Procedures, or Procedure for Security Event reporting.

• People — make employees aware of why reporting security events is needed, and train them on how to identify and report a security event.

4. **Include examples of evidence that could be used to demonstrate compliance**

   - **A.6.3 Information security awareness, education, and training:** A program to ensure that all employees are aware of their information security responsibilities.
   - **A.6.4 Disciplinary process:** A formal disciplinary process for employees who have committed an information security violation.
   - **A.6.7 Remote working:** A policy and supporting security measures for employees who work remotely.

Task 3: CIS Controls Prioritization and Implementation

Step 2: Analyze and Recommend

1. **Write a summary of the CIS Controls v8 and explain the purpose of the Implementation Groups:** The CIS Critical Security Controls started as a simple grassroots activity to identify the most common and important real-world cyber-attacks that affect Organization every day, translate that knowledge and experience into positive, constructive action for defenders, and then share that information with a wider audience. The original goals were modest to help people and Organization focus their attention and get started on the most important steps to defend themselves from the attacks that really mattered.

   The CIS Controls reflect the combined knowledge of experts from every part of the ecosystem (companies, governments, individuals), with every role (threat responders and analysts, technologists, information technology (IT) operators and defenders, vulnerability-finders, tool makers, solution providers, users, policy-makers, auditors, etc.), and across many sectors (government, power, defense, finance, transportation, academia, consulting, security, IT, etc.), who have banded together to create, adopt, and support the CIS Controls

   purpose of the Implementation Groups (IG)

• **IG1:** An IG1 enterprise is small to medium-sized with limited IT and cybersecurity expertise to dedicate towards protecting IT assets and personnel. The principal concern of these Organization is to keep the business operational, as they have a limited tolerance for downtime. The sensitivity of the data that they are trying to protect is low and principally surrounds employee and financial information. Safeguards selected for IG1 should be implementable with limited cybersecurity expertise and aimed to thwart general, non-targeted attacks. These Safeguards will also typically be designed to work in conjunction with small or home office commercial off the-shelf (COTS) hardware and software

• **IG2** (Includes IG1) An IG2 enterprise employs individuals responsible for managing and protecting IT infrastructure. These Organization support multiple departments with differing risk profiles based on job function and mission. Small enterprise units may have regulatory compliance burdens. IG2 Organization often store and process sensitive client or enterprise information and can withstand short interruptions of service. A major concern is loss of public confidence if a breach occurs. Safeguards selected for IG2 help security teams cope with increased operational complexity. Some Safeguards will depend on enterprise-grade technology and specialized expertise to properly install and configure. IG3 (Includes IG1 and IG2) An IG3 enterprise employs security experts that specialize in the different facets of cybersecurity (e.g., risk management, penetration testing, application security).

• **IG3** assets and data contain sensitive information or functions that are subject to regulatory and compliance oversight. An IG3 enterprise must address availability of services and the confidentiality and integrity of sensitive data. Successful attacks can cause

significant harm to the public welfare. Safeguards selected for IG3 must abate targeted attacks from a sophisticated adversary and reduce the impact of zero-day attacks.

The CIS Controls are designed so that:

• Small, low-risk organizations (IG1) implement only the most essential safeguards.

• Medium-maturity organizations (IG2) implement more.

• Highly mature organizations (IG3) implement all safeguards.

2. **Recommend the most appropriate Implementation Group for SecureHealth and justify your choice.**

   Answer

   The appropriate implementation group for SecureHealth is IG2 because adopt a cybersecurity framework to mature their security program.

Justification for IG2 is because SecureHealth is a regional healthcare provider with three clinics, they have a small IT team, and handle patient sensitive data, They have a limited budget and need a flexible, risk-based approach.

Step 3: Create a Prioritized Plan

1. **Create a prioritized implementation plan for the top 5 CIS Controls from your recommended IG.**

   Answers

A. **Control 1: Inventory and Control of Enterprise Assets:** Actively manage (inventory, track, and correct) all organization assets (end-user devices, including portable and mobile; network devices; non-computing/Internet of Things (IoT) devices; and servers) connected to the infrastructure physically, virtually, remotely, and those within cloud environments, to accurately know the totality of assets that need to be monitored and protected within the enterprise. This will also support identifying unauthorized and unmanaged assets to remove or remediate.

SAFEGUARDS TOTAL - 5

IG1 - 2/5 means implement 2 safeguards out of 5 which is the minimum baseline.

IG2 - 4/5 - means organization are to implement 4 out of 5 safeguards

IG3 - 5/5 - means organization are to implement all the 5 safeguards

The safeguards are;

Safeguards	Asset Type	Security Function
Establish and Maintain Detailed Enterprise Asset Inventory	Device	Identify

Address Unauthorized Assets	Device	Respond
Utilize an Active Discovery Tool	Device	Detect
Use Dynamic Host Configuration Protocol (DHCP) Logging to Update Enterprise Asset Inventory	Device	Identify
Use Dynamic Host Configuration Protocol (DHCP) Logging to Update Enterprise Asset Inventory	Device	Detect

Key Actions

Create an enterprise asset inventory

Identify all laptops, servers, medical devices

Remove unauthorized devices

Implement active discovery tools

Use DHCP logging to track new devices

IG2 Requirement: Implement 4 out of 5 safeguards

B. **Inventory and Control of Software Assets**: Actively manage (inventory, track, and correct) all software (operating systems and applications) on the network so that only authorized software is installed and can execute, and that unauthorized and unmanaged software is found and prevented from installation or execution.

SAFEGUARDS TOTAL - 7, IG1 - 3/7, IG2 - 6/7, IG3 - 7/7

The safeguards are;

Safeguards	Asset Type	Security Function
Establish and Maintain a Software Inventory	Application	Identify
Ensure Authorized Software is Currently Supported	Application	Identify
Address Unauthorized Software	Application	Respond
Utilize Automated Software Inventory Tools	Application	Detect
Allow-list Authorized Software	Application	Protect
Allowlist Authorized Libraries	Application	Protect
Allowlist Authorized Scripts	Application	Protect

Actions

Create software inventory

Remove unapproved applications

Enable auto updates

Standardize software images

IG2 Requirement: Implement 6 out of 7 safeguards

C. **Data Protection:** Develop processes and technical controls to identify, classify, securely handle, retain, and dispose of data.Data is no longer only contained within an enterprise's border; it is in the cloud, on portable end-user devices where users work from home, and is often shared with partners or online services that might have it anywhere in the world. In addition to sensitive data an enterprise holds related to finances, intellectual property, and customer data, there also might be numerous international regulations for protection of personal data. These privacy rules can be complicated for multi-national enterprises of any size; however, there are fundamentals that can apply to all.

SAFEGUARDS TOTAL - 14, IG1 - 6/14, IG2 - 12/14, IG3 - 14. the safeguards are;

Safeguards	**Asset Type**	**Security Function**
Establish and Maintain a Data Management Process	Data	Identify
Establish and Maintain a Data Inventory	Data	Identify
Configure Data Access Control Lists	Data	Protect
Enforce Data Retention	Data	Protect
Securely Dispose of Data	Data	Protect
Encrypt Data on End-User Devices	Data	Protect
Establish and Maintain a Data Classification Scheme	Data	Identify
Document Data Flows	Data	Identify
Encrypt Data on Removable Media	Data	Protect
Encrypt Sensitive Data in Transit	Data	Protect
Encrypt Sensitive Data at Rest	Data	Protect
Segment Data Processing and Storage Based on Sensitivity	Network	Protect
Deploy a Data Loss Prevention Solution	Data	Protect
Log Sensitive Data Access	Data	Detect

Actions

Implement MFA

Remove inactive accounts

Enforce least privilege

Formal onboarding/offboarding

IG2 Requirement: Implement 12 out of 14 safeguards

D. **Control 5 – Account Management:** Use processes and tools to assign and manage authorization to credentials for user accounts, including administrator accounts, as well as service accounts, to enterprise assets and software.

SAFEGUARDS TOTAL - 6, IG1 - 4/6, IG2 - 6/6, IG3 - 6/6. The safeguards are;

Safeguards	**Asset Type**	**Security Function**
Establish and Maintain an Inventory of Accounts	Users	Identify
Use Unique Passwords	Users	Protect
Disable Dormant Accounts	Users	Respond
Restrict Administrator Privileges to Dedicated Administrator Accounts	Users	Protect
Establish and Maintain an Inventory of Service Accounts	Users	Identify
Centralize Account Management	Users	Protect

Actions

Implement MFA

Remove inactive accounts

Enforce least privilege

Formal onboarding/offboarding

IG2 Requirement: Implement 6 out of 6 safeguards

E. **Control 17 – Incident Response Management:** Establish a program to develop and maintain an incident response capability (e.g., policies, plans, procedures, defined roles, training, and communications) to prepare, detect, and quickly respond to an attack.

SAFEGUARDS TOTAL - 9, IG1 - 3/9, IG2 - 8/9, IG3 - 9/9. The safeguards are;

Safeguards	**Asset Type**	**Security Function**
Designate Personnel to Manage Incident Handling	N/A	Respond
Establish and Maintain Contact Information for Reporting Security Incidents	N/A	Respond
Establish and Maintain an Enterprise Process for Reporting Incidents	N/A	Respond
Establish and Maintain an Incident Response Process	N/A	Respond
Assign Key Roles and Responsibilities	N/A	Respond
Define Mechanisms for Communicating During Incident	N/A	Respond

Response		
Conduct Routine Incident Response Exercises	N/A	Recover
Conduct Post-Incident Reviews	N/A	Recover
Establish and Maintain Security Incident Thresholds	N/A	Recover

Actions

Develop incident response plan

Create reporting channels

Conduct incident drills

IG2 Requirement: Implement 8 out of 9 safeguards

2. **For each of the top 5 controls, explain its relevance to SecureHealth, describe their likely current state, and provide implementation steps.**

Control 1 – Inventory And Control Of Enterprise Assets: IT IS Relevance to SecureHealth because SecureHealth operates across three different clinic locations and the devices include: Medical devices, Laptops, Network equipment, Workstations and Servers.

Likely Current State: Given the organization size and small IT team, the current state is likely, No centralized asset inventory, Informal tracking of devices, Devices added without formal approval and Limited visibility into network-connected systems

Implementation Steps

- Create a centralized asset inventory register
- Identify and document all
- Computers
- Servers
- Network devices
- Printers
- Medical systems
- Deploy a basic network discovery tool
- Assign ownership to each asset
- Establish a procedure for adding/removing assets

Control 2 – Inventory And Control Of Software Assets: it is relevance to SecureHealth because the

Healthcare environments often run, Electronic Medical Record (EMR) software, Billing applications

Diagnostic tools

Likely Current State: SecureHealth likely has No formal list of approved software, Staff installing applications freely, Outdated or unsupported applications and Inconsistent patching

Implementation Steps

- Create an approved software list
- Scan all systems to identify installed applications
- Remove unauthorized or risky software
- Restrict installation rights to IT staff
- Enable automatic updates

Control 3 – Data Protection: it is relevance to SecureHealth and it is the most critical control for SecureHealth because they manage they Patient medical records, Personal health information (PHI)

Likely Current State: Currently SecureHealth may have Limited encryption, Inconsistent backups

Unrestricted data sharing, and Lack of data classification

Implementation Steps: Define data classification categories;

- Encrypt
- Laptops
- Backups
- Data transfers
- Implement secure backups
- Restrict USB and removable media
- Secure email communications

CONTROL 5 – ACCOUNT MANAGEMENT: it is relevance to SecureHealth and essential because many staff access patient systems, unauthorized access could expose sensitive data and shared or weak accounts increase breach risk

Likely Current State: SecureHealth probably has shared user accounts, weak password practices, no multi-factor authentication and ooor offboarding processes

Implementation Steps: Implement centralized identity management

- Enforce strong password policies
- Deploy Multi-Factor Authentication (MFA)
- Remove inactive accounts
- Create onboarding/offboarding procedures

Control 17 – Incident Response Management: it is relevance to SecureHealth and crucial because

they already experienced a minor data breach, future incidents are likely and staff need to know how to react quickly

Likely Current State: SecureHealth likely has no formal incident response plan, Ad-hoc reaction to incidents, and no structured reporting process

Implementation Steps

- Develop an Incident Response Plan
- Define an incident response team
- Establish reporting channels
- Create incident documentation templates

Task 5: Framework Comparison and Recommendation

Step 1: Create a Comparison Table

Create a comparison table that outlines the key characteristics of NIST CSF 2.0, ISO 27001:2022, and CIS Controls v8.

Include aspects like: intended audience, cost, complexity, flexibility, and certification options.

	NIST CSF 2.0	**ISO 27001**	**CIS CONTROL v8**
Key Characteristics	NIST CSF 2.0 is a voluntary framework that help organization, regardless of their size, maturity, and sector (government, industry, academia, nonprofit etc) to reduce or improve their cybersecurity posture. The Framework is not a one-size-fits-all approach to managing cybersecurity risks. It can be used by organizations to understand, assess, prioritize, and communicate cybersecurity risks It include the following components 1. CST Core which include the Govern, Identify, Protect, Detect, Respond and Recover 2. CSF Organizational profile which include the current and target profile of	It was developed to address the evolving cybersecurity landscape, the increasing reliance on cloud services, and the need for a more streamlined and effective approach to information security management. For auditors, understanding these changes is crucial for assessing an organization's compliance and the effectiveness of its ISMS. Following the release of ISO 27002:2022 (Information security, cybersecurity and privacy protection controls) on February 15, 2022, ISO 27001:2022 has aligned its Annex A controls. The new version of the Standard draws upon a condensed set of 93 Annex A controls, including 11 new	The CIS Critical Security Controls (CIS Controls) are a prioritized set of CIS Safeguards to defend against the most prevalent cyber attacks against systems and networks. They are mapped to and referenced by multiple legal, regulatory, and policy frameworks. • **IG1:** An IG1 enterprise is small to medium-sized with limited IT and cybersecurity expertise to dedicate towards protecting IT assets and personnel. The principal concern of these Organization is to keep the business operational, as they have a limited tolerance for downtime. The sensitivity of the data that they are trying to protect is low and principally surrounds

	the organization 3. Tier which are Tier 1 - Partial, Tier 2 - risk informed, Tier 3 - Repeatable and Tier 4 - Adaptive.	controls. A total of 24 controls were merged from two, three, or more security controls from the 2013 version, and 58 controls from the ISO 27002:2013 were revised to align with the current cyber security and information security environment. The Annex A control categories are 1 . Organizational control with 37 control 2. People with 8 controls 3. Physical with 14 control 4. Technological with 34 control	employee and financial information. Safeguards selected for • **IG2** (Includes IG1) An IG2 enterprise employs individuals responsible for managing and protecting IT infrastructure. These Organization support multiple departments with differing risk profiles based on job function and mission. IG2 Organization often store and process sensitive client or enterprise information and can withstand short interruptions of service • **IG3** assets and data contain sensitive information or functions that are subject to regulatory and compliance oversight. An IG3 enterprise must address availability of services and the confidentiality and integrity of sensitive data. Successful attacks can cause significant harm to the public welfare.
I ntended Aud ience	All kind of organization, either small, medium and large organization	Medium and Large organization especially those who interested	Small to medium organization

		in international certification	
• *Cost**	Low	High due to cost of certification and auditors	Low
Complexity	Moderate	High	Moderate
• *Flexibility**	Very flexible as it can be used for all kind of organization and structure	Not Flexible as there are different requirement organization must met	Flexible
• *Certification Options**	No	Yes	No

Step 2: Make Recommendations

For each of the three scenarios, recommend the most appropriate framework.

Provide a brief justification for each of your choices.

Scenarios

- **Scenario A**: A large, multinational corporation that needs a formal, internationally recognized security certification.

  Answer

  Recommended Framework: ISO 27001

  Justification: The organization is a large, mutinational corporation and it need a formal and international recognition and it is only ISO 27001 that provide global recognition and certification. ISO 27001 have a strong governance and documentation and has auditable processes that international partners can trust

- **Scenario B**: A small, non-profit organization with a very limited budget and IT staff that needs to improve its basic security hygiene.

  Answer

  Recommended Framework: CIS Control v8

Justification: The organization is a small, non-profit with very limited budget and IT staff and CIS Control v8 is a low cost, limited resources and small IT staff can handles the basic security hygiene with CIS Control v8 framework,

- Scenario C: A mid-sized technology company that wants a flexible, risk-based framework to guide its security program but does not necessarily need a certification.

Answer

Recommended Framework: NIST CSF 2.0

Justification: The organization is a mid size technology and it is flexible, risk based and that is why NIST CSF 2.0 is best approriate framework and it does not necessarily need a certification which is best for NIST CSF 2.0

Task 2: ISO 27001 Control Implementation Analysis

Scenario

You are a security consultant hired by a mid-sized e-commerce company. They want to improve their security posture and are considering ISO 27001 certification. Your task is to help them understand a specific set of controls.

Step 1: Research ISO 27001:2022

Research the ISO 27001:2022 standard, focusing on the controls listed in Annex A. Use the resources provided in the appendix of this document.

Step 2: Select a Control Family

1. Choose **one** of the following control families from Annex A to focus on:

   A.6: People controls: People controls enable businesses to regulate the human component of their information security program, by defining the manner in which personnel interact with data and each other. These controls cover secure human resources management, personnel security, and awareness and training.

   • Number of contol: 8

   • Contol numbers:ISO 27001 Annex A 6.1 to 6.8

Step 3: Create an Implementation Guide

1. For your selected control family, write a detailed implementation guide.

The People control: This control describes 8 controls related to secure management of human resources:

2. **Explain the purpose of the controls in that family.**

Answer

The people control This group of 8 controls addresses the human element of information security. They are designed to ensure that people are a strong line of defense, not a weak link.

3. **Provide practical, step-by-step instructions on how an organization could implement them.**

Answer

Control 6.1 - Screening control

ISO 27001 control A.6.1 Screening requires companies to conduct background checks of employees and third-party personnel on an ongoing basis in accordance with applicable laws and regulations, in order to employ only trusted people.

Implementation

In order to comply with control A.6.1 Screening, organization might implement the following:

• Technology — the technology to enable the background check of job candidates, or external suppliers, may include Internet access to social networks, professional associations, and legal authorities, within the applicable legal limits.

• Organization/processes — you should set up a process for defining who is in charge of performing background checks, for which jobs, and in which circumstances. You can document those processes through a Screening Procedure or a Supplier Security Policy

• People — make employees aware of why performing background checks is needed, and train employees on how and when to perform them.

Control 6.2 - Terms and conditions of employment control

ISO 27001 control A.6.2 Terms and conditions of employment requires companies to include security clauses in their agreements with employees and third parties, in order for everyone to know exactly what is expected of them with regard to security

Implementation

In order to comply with control A.6.2 Terms and conditions of employment you might implement the following:

• Technology — companies of all sizes may use existing tools to handle documents to write and sign security clauses in agreements with employees and suppliers.

• Organization/processes — you should set up a process for defining which information security requirements must be included as terms and conditions of employment. You can document those processes by inserting security clauses into existing agreements with the personnel; alternatively, some additional documents can be signed, like a Statement of Acceptance of ISMS Documents, a confidentiality Statement, or NDAs.

• People — make employees aware of why security terms and conditions are needed, and train HR personnel on how to identify and include them in the company's documentation.

Control 6.3 - information security awareness, education and training: ISO 27001 control A.6.3 Information security awareness, education and training requires companies to explain to relevant people why security is needed, and how to comply with various security requirements. This is important in order to avoid people's resentment and noncompliance because of not knowing how to perform security activities.

Implementation: In order to comply with control A.6.3 Information security awareness, education and training organization should implement the following:

• Technology — the technology to enable information security awareness, education, and training may include software to develop the material, and access to Internet to share the material with employees and contractors. Small companies may simply use current office

applications, while bigger companies may use learning platforms to share material and assess and evaluate learning.

• Organization/processes — you should set up a process for defining which material must be developed, for whose audience, how often it must be presented, and how the effectiveness of the presentation is going to be measured. You can document those processes through a Training and awareness plan or a Training & Awareness Procedure.

• People — train HR personnel on how to develop and deliver security awareness and training.

Contol 6.4 - Disciplinary process: ISO 27001 control A.6.4 Disciplinary process requires companies to perform a formal disciplinary process against people who have performed a violation of information security rules, in order to establish whether such breach was intentional.

Implementation

In order to comply with control A.6.4 Disciplinary process you might implement the following:

• Technology — the technology to enable disciplinary processes may include forensic software to support the investigation of the most relevant incidents and hardware to securely store digital evidence. Small companies may use outsourced services when needed, while bigger companies may have a dedicated team and tools for such investigations.

• Organization/processes — you should set up a process for defining who must be involved in disciplinary processes, and the steps to be performed. You can document those processes through an incident management procedure or a Disciplinary Procedure.

• People — make employees aware of why performing disciplinary processes is needed, and train required personnel on how to perform them.

Control 6.5 - Responsibilities after termination or change of employment: ISO 27001 control A.6.5 Responsibilities after termination or change of employment requires companies to define which security duties will remain valid after a person leaves the company or changes the position within the company. This is done to avoid any unclear responsibilities after the change of a person's status. This can be done by including security clauses in the termination agreements or in annexes.

Implementation: In order to comply with control A.6.5 Responsibilities after termination or change of employment, you might implement the following:

• Technology — the technology to enforce the responsibilities after termination or change of employment may include access to systems and social media that enable monitoring (within legal restrictions) of ex-employees activities after employment.

• Organization/processes — you should set up a process for defining which information security requirements must be enforced after termination or change of employment. You

can document those processes by inserting security clauses into Confidentiality Statement, Termination Agreement, or similar documents.

• People — make employees aware of why defining responsibilities that need to be kept after termination or change of employment is needed, and train HR personnel on how to include them in proper documentation and make personnel aware of such requirements during the termination process.

Control 6.6 – Confidentiality or non-disclosure agreements: ISO 27001 control A.6.6 Confidentiality or non-disclosure agreements requires companies to define such agreements and sign them with all employees and relevant third parties, in order for everyone to know the requirements for protecting the information.

Implementation: In order to comply with control A.6.6 Confidentiality or non-disclosure agreements you might implement the following:

• Technology — the tools to write and sign confidentiality and non-disclosure agreements may be the same ones used to handle other documents.

• Organization/processes — you should set up a process for defining the criteria with whom to sign confidentiality and non-disclosure agreements, and what should be their content. You can then create templates for Confidentiality Statement or NDAs.

• People — make employees aware of why confidentiality statements and NDAs are needed and train HR personnel on how to develop them, and make personnel aware of such requirements.

Control 6.7 - Remote working: ISO 27001 control A.6.7 Remote working requires companies to define security rules when people are working from home or from other remote locations, in order to protect the information that is processed outside of the company's premises.

Implementation: In order to comply with control A.6.7 Remote working you might implement the following:

• Technology — the technology to enable remote working may include software (e.g., data loss prevention software, software for remote management, etc.), hardware (e.g., dedicated devices to be used remotely), and networks (e.g., VPN, dedicated links, etc.).

• Organization/processes — you should set up a process for defining criteria to allow remote work, minimum requirements for devices allowed to be used for remote work, who must authorize remote work, and what users can and can't do while working remotely. You can document those processes through Mobile Device and Remote Work Policy.

• People — make employees aware of the risks of working remotely, and train them on what they can and cannot do while teleworking.

Control 6.8 - Information security event reporting: ISO 27001 control A.6.8 Information security event reporting requires companies to enable people to report security events and incidents as quickly as possible, in order to prevent some larger damage.

Implementation: In order to comply with control A.6.8 Information security event reporting you might implement the following:

• Technology — the technology for event reporting could include software, hardware, networks, or communication. Smaller companies will probably be able to report events through phone calls, message applications, or other means of communication, whereas larger companies probably need some software that centralizes reports from all available channels and redirects them to the proper personnel to treat each one of them.

• Organization/processes — you should set up a process for identifying proper channels to report security events, to whom such reports need to be sent, and which information should be reported. You can document those processes through Incident Management Procedures, or Procedure for Security Event reporting.

• People — make employees aware of why reporting security events is needed, and train them on how to identify and report a security event.

4. **Include examples of evidence that could be used to demonstrate compliance**

   - **A.6.3 Information security awareness, education, and training:** A program to ensure that all employees are aware of their information security responsibilities.
   - **A.6.4 Disciplinary process:** A formal disciplinary process for employees who have committed an information security violation.
   - **A.6.7 Remote working:** A policy and supporting security measures for employees who work remotely.

Task 3: CIS Controls Prioritization and Implementation

Step 2: Analyze and Recommend

1. **Write a summary of the CIS Controls v8 and explain the purpose of the Implementation Groups:** The CIS Critical Security Controls started as a simple grassroots activity to identify the most common and important real-world cyber-attacks that affect Organization every day, translate that knowledge and experience into positive, constructive action for defenders, and then share that information with a wider audience. The original goals were modest to help people and Organization focus their attention and get started on the most important steps to defend themselves from the attacks that really mattered.

   The CIS Controls reflect the combined knowledge of experts from every part of the ecosystem (companies, governments, individuals), with every role (threat responders and analysts, technologists, information technology (IT) operators and defenders, vulnerability-finders, tool makers, solution providers, users, policy-makers, auditors, etc.), and across many sectors (government, power, defense, finance, transportation, academia, consulting, security, IT, etc.), who have banded together to create, adopt, and support the CIS Controls

   purpose of the Implementation Groups (IG)

• **IG1:** An IG1 enterprise is small to medium-sized with limited IT and cybersecurity expertise to dedicate towards protecting IT assets and personnel. The principal concern of these Organization is to keep the business operational, as they have a limited tolerance for downtime. The sensitivity of the data that they are trying to protect is low and principally surrounds employee and financial information. Safeguards selected for IG1 should be implementable with limited cybersecurity expertise and aimed to thwart general, non-targeted attacks. These Safeguards will also typically be designed to work in conjunction with small or home office commercial off the-shelf (COTS) hardware and software

• **IG2** (Includes IG1) An IG2 enterprise employs individuals responsible for managing and protecting IT infrastructure. These Organization support multiple departments with differing risk profiles based on job function and mission. Small enterprise units may have regulatory compliance burdens. IG2 Organization often store and process sensitive client or enterprise information and can withstand short interruptions of service. A major concern is loss of public confidence if a breach occurs. Safeguards selected for IG2 help security teams cope with increased operational complexity. Some Safeguards will depend on enterprise-grade technology and specialized expertise to properly install and configure. IG3 (Includes IG1 and IG2) An IG3 enterprise employs security experts that specialize in the different facets of cybersecurity (e.g., risk management, penetration testing, application security).

• **IG3** assets and data contain sensitive information or functions that are subject to regulatory and compliance oversight. An IG3 enterprise must address availability of services and the confidentiality and integrity of sensitive data. Successful attacks can cause

significant harm to the public welfare. Safeguards selected for IG3 must abate targeted attacks from a sophisticated adversary and reduce the impact of zero-day attacks.

The CIS Controls are designed so that:

• Small, low-risk organizations (IG1) implement only the most essential safeguards.

• Medium-maturity organizations (IG2) implement more.

• Highly mature organizations (IG3) implement all safeguards.

2. **Recommend the most appropriate Implementation Group for SecureHealth and justify your choice.**

   Answer

   The appropriate implementation group for SecureHealth is IG2 because adopt a cybersecurity framework to mature their security program.

Justification for IG2 is because SecureHealth is a regional healthcare provider with three clinics, they have a small IT team, and handle patient sensitive data, They have a limited budget and need a flexible, risk-based approach.

Step 3: Create a Prioritized Plan

1. **Create a prioritized implementation plan for the top 5 CIS Controls from your recommended IG.**

   Answers

A. **Control 1: Inventory and Control of Enterprise Assets:** Actively manage (inventory, track, and correct) all organization assets (end-user devices, including portable and mobile; network devices; non-computing/Internet of Things (IoT) devices; and servers) connected to the infrastructure physically, virtually, remotely, and those within cloud environments, to accurately know the totality of assets that need to be monitored and protected within the enterprise. This will also support identifying unauthorized and unmanaged assets to remove or remediate.

SAFEGUARDS TOTAL - 5

IG1 - 2/5 means implement 2 safeguards out of 5 which is the minimum baseline.

IG2 - 4/5 - means organization are to implement 4 out of 5 safeguards

IG3 - 5/5 - means organization are to implement all the 5 safeguards

The safeguards are;

Safeguards	Asset Type	Security Function
Establish and Maintain Detailed Enterprise Asset Inventory	Device	Identify

Address Unauthorized Assets	Device	Respond
Utilize an Active Discovery Tool	Device	Detect
Use Dynamic Host Configuration Protocol (DHCP) Logging to Update Enterprise Asset Inventory	Device	Identify
Use Dynamic Host Configuration Protocol (DHCP) Logging to Update Enterprise Asset Inventory	Device	Detect

Key Actions

Create an enterprise asset inventory

Identify all laptops, servers, medical devices

Remove unauthorized devices

Implement active discovery tools

Use DHCP logging to track new devices

IG2 Requirement: Implement 4 out of 5 safeguards

B. **Inventory and Control of Software Assets**: Actively manage (inventory, track, and correct) all software (operating systems and applications) on the network so that only authorized software is installed and can execute, and that unauthorized and unmanaged software is found and prevented from installation or execution.

SAFEGUARDS TOTAL - 7, IG1 - 3/7, IG2 - 6/7, IG3 - 7/7

The safeguards are;

Safeguards	Asset Type	Security Function
Establish and Maintain a Software Inventory	Application	Identify
Ensure Authorized Software is Currently Supported	Application	Identify
Address Unauthorized Software	Application	Respond
Utilize Automated Software Inventory Tools	Application	Detect
Allow-list Authorized Software	Application	Protect
Allowlist Authorized Libraries	Application	Protect
Allowlist Authorized Scripts	Application	Protect

Actions

Create software inventory

Remove unapproved applications

Enable auto updates

Standardize software images

IG2 Requirement: Implement 6 out of 7 safeguards

C. **Data Protection:** Develop processes and technical controls to identify, classify, securely handle, retain, and dispose of data.Data is no longer only contained within an enterprise's border; it is in the cloud, on portable end-user devices where users work from home, and is often shared with partners or online services that might have it anywhere in the world. In addition to sensitive data an enterprise holds related to finances, intellectual property, and customer data, there also might be numerous international regulations for protection of personal data. These privacy rules can be complicated for multi-national enterprises of any size; however, there are fundamentals that can apply to all.

SAFEGUARDS TOTAL - 14, IG1 - 6/14, IG2 - 12/14, IG3 - 14. the safeguards are;

Safeguards	**Asset Type**	**Security Function**
Establish and Maintain a Data Management Process	Data	Identify
Establish and Maintain a Data Inventory	Data	Identify
Configure Data Access Control Lists	Data	Protect
Enforce Data Retention	Data	Protect
Securely Dispose of Data	Data	Protect
Encrypt Data on End-User Devices	Data	Protect
Establish and Maintain a Data Classification Scheme	Data	Identify
Document Data Flows	Data	Identify
Encrypt Data on Removable Media	Data	Protect
Encrypt Sensitive Data in Transit	Data	Protect
Encrypt Sensitive Data at Rest	Data	Protect
Segment Data Processing and Storage Based on Sensitivity	Network	Protect
Deploy a Data Loss Prevention Solution	Data	Protect
Log Sensitive Data Access	Data	Detect

Actions

Implement MFA

Remove inactive accounts

Enforce least privilege

Formal onboarding/offboarding

IG2 Requirement: Implement 12 out of 14 safeguards

D. **Control 5 – Account Management:** Use processes and tools to assign and manage authorization to credentials for user accounts, including administrator accounts, as well as service accounts, to enterprise assets and software.

SAFEGUARDS TOTAL - 6, IG1 - 4/6, IG2 - 6/6, IG3 - 6/6. The safeguards are;

Safeguards	**Asset Type**	**Security Function**
Establish and Maintain an Inventory of Accounts	Users	Identify
Use Unique Passwords	Users	Protect
Disable Dormant Accounts	Users	Respond
Restrict Administrator Privileges to Dedicated Administrator Accounts	Users	Protect
Establish and Maintain an Inventory of Service Accounts	Users	Identify
Centralize Account Management	Users	Protect

Actions

Implement MFA

Remove inactive accounts

Enforce least privilege

Formal onboarding/offboarding

IG2 Requirement: Implement 6 out of 6 safeguards

E. **Control 17 – Incident Response Management:** Establish a program to develop and maintain an incident response capability (e.g., policies, plans, procedures, defined roles, training, and communications) to prepare, detect, and quickly respond to an attack.

SAFEGUARDS TOTAL - 9, IG1 - 3/9, IG2 - 8/9, IG3 - 9/9. The safeguards are;

Safeguards	**Asset Type**	**Security Function**
Designate Personnel to Manage Incident Handling	N/A	Respond
Establish and Maintain Contact Information for Reporting Security Incidents	N/A	Respond
Establish and Maintain an Enterprise Process for Reporting Incidents	N/A	Respond
Establish and Maintain an Incident Response Process	N/A	Respond
Assign Key Roles and Responsibilities	N/A	Respond
Define Mechanisms for Communicating During Incident	N/A	Respond

Response		
Conduct Routine Incident Response Exercises	N/A	Recover
Conduct Post-Incident Reviews	N/A	Recover
Establish and Maintain Security Incident Thresholds	N/A	Recover

Actions

Develop incident response plan

Create reporting channels

Conduct incident drills

IG2 Requirement: Implement 8 out of 9 safeguards

2. **For each of the top 5 controls, explain its relevance to SecureHealth, describe their likely current state, and provide implementation steps.**

Control 1 – Inventory And Control Of Enterprise Assets: IT IS Relevance to SecureHealth because SecureHealth operates across three different clinic locations and the devices include: Medical devices, Laptops, Network equipment, Workstations and Servers.

Likely Current State: Given the organization size and small IT team, the current state is likely, No centralized asset inventory, Informal tracking of devices, Devices added without formal approval and Limited visibility into network-connected systems

Implementation Steps

- Create a centralized asset inventory register
- Identify and document all
- Computers
- Servers
- Network devices
- Printers
- Medical systems
- Deploy a basic network discovery tool
- Assign ownership to each asset
- Establish a procedure for adding/removing assets

Control 2 – Inventory And Control Of Software Assets: it is relevance to SecureHealth because the

Healthcare environments often run, Electronic Medical Record (EMR) software, Billing applications

Diagnostic tools

Likely Current State: SecureHealth likely has No formal list of approved software, Staff installing applications freely, Outdated or unsupported applications and Inconsistent patching

Implementation Steps

- Create an approved software list
- Scan all systems to identify installed applications
- Remove unauthorized or risky software
- Restrict installation rights to IT staff
- Enable automatic updates

Control 3 – Data Protection: it is relevance to SecureHealth and it is the most critical control for SecureHealth because they manage they Patient medical records, Personal health information (PHI)

Likely Current State: Currently SecureHealth may have Limited encryption, Inconsistent backups

Unrestricted data sharing, and Lack of data classification

Implementation Steps: Define data classification categories;

- Encrypt
- Laptops
- Backups
- Data transfers
- Implement secure backups
- Restrict USB and removable media
- Secure email communications

CONTROL 5 – ACCOUNT MANAGEMENT: it is relevance to SecureHealth and essential because many staff access patient systems, unauthorized access could expose sensitive data and shared or weak accounts increase breach risk

Likely Current State: SecureHealth probably has shared user accounts, weak password practices, no multi-factor authentication and ooor offboarding processes

Implementation Steps: Implement centralized identity management

- Enforce strong password policies
- Deploy Multi-Factor Authentication (MFA)
- Remove inactive accounts
- Create onboarding/offboarding procedures

Control 17 – Incident Response Management: it is relevance to SecureHealth and crucial because

they already experienced a minor data breach, future incidents are likely and staff need to know how to react quickly

Likely Current State: SecureHealth likely has no formal incident response plan, Ad-hoc reaction to incidents, and no structured reporting process

Implementation Steps

- Develop an Incident Response Plan
- Define an incident response team
- Establish reporting channels
- Create incident documentation templates

B6: Data are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information

Control ID/Name	Control Description	Current Implementation Status (Not Implemented, Partially	Gap Description	Recommended Remediation	Priority (High, Medium, Low)
GV.PO - Policy	Establish FinCorp policies and it should be communicated and enforced	Partially implemented	No formal cybersecurity policies in place at FinCorp	Develop all cybersecurity policies for FinCorp	High
ID.AM - Asset Management	inventories of FinCorp software, hardware should be managed, maintained and assets should be prioritied based on classification, critically and resources	Not Implemented	No inventories of hardware, device etc	Develop a central inventories database	High
PR.AA - Identity management, Authentication, and Access Control	Access to physical and logical assets should be limited to authorized users only	Partially implemented	Password policy exited but other policy related to access control not in place like MFA	Develop other related policies and access based policy like MFA	High
PR.AT - Awareness and Training	FinCorp employeee should be provided with cybersecurity awareness and training	Not Implemented	They have 25 employees and are growing rapidly without training on cybersecurity risk	Quarterly training of senior executive, employees and other stakeholder on cybersecurity risk	High
PR.DS - Data Security	Data are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information	Partially implemented	encryption should be standardized	Data of FinCorp customers should protected because of the kind of information it stored	High
DE.CM - Continuous Monitoring	Assets should be monitored to find anomalies, indicator of compromise and other ptentially adverse events	Not Implemented	No continuous monitoring in place	Implement monitoring solution to monitor the network, physical environment, personal activity and	High
RS.MA - Incident Management	Responses to detected cybersecurity incidents are managed	Not Implemented	Incident response are not managed,escalated, reported, categorized and prioritized as when needed	Implement Incident response plan	High
RS.CO - Incident reporting and communication	Response activities are coordinated with internal and external stakeholders as required by laws, regulations, or policies	Not Implemented	No specific mode of incident reporting and communication	A define mode of communication with internal and external stakeholders should be communicated	Medium
RC.RP - Incident recovery plan execution	Restoration activities are performed to ensure operational availability of systems and services affected by cybersecurity incidents	Partially implemented	Backups exist but no formal recovery plan and execution	Develop a formal recovery plan and execution	Medium

Task 5: Framework Comparison and Recommendation

Step 1: Create a Comparison Table

Create a comparison table that outlines the key characteristics of NIST CSF 2.0, ISO 27001:2022, and CIS Controls v8.

Include aspects like: intended audience, cost, complexity, flexibility, and certification options.

	NIST CSF 2.0	**ISO 27001**	**CIS CONTROL v8**
Key Characteristics	NIST CSF 2.0 is a voluntary framework that help organization, regardless of their size, maturity, and sector (government, industry, academia, nonprofit etc) to reduce or improve their cybersecurity posture. The Framework is not a one-size-fits-all approach to managing cybersecurity risks. It can be used by organizations to understand, assess, prioritize, and communicate cybersecurity risks It include the following components 1. CST Core which include the Govern, Identify, Protect, Detect, Respond and Recover 2. CSF Organizational profile which include the current and target profile of	It was developed to address the evolving cybersecurity landscape, the increasing reliance on cloud services, and the need for a more streamlined and effective approach to information security management. For auditors, understanding these changes is crucial for assessing an organization's compliance and the effectiveness of its ISMS. Following the release of ISO 27002:2022 (Information security, cybersecurity and privacy protection controls) on February 15, 2022, ISO 27001:2022 has aligned its Annex A controls. The new version of the Standard draws upon a condensed set of 93 Annex A controls, including 11 new	The CIS Critical Security Controls (CIS Controls) are a prioritized set of CIS Safeguards to defend against the most prevalent cyber attacks against systems and networks. They are mapped to and referenced by multiple legal, regulatory, and policy frameworks. • **IG1:** An IG1 enterprise is small to medium-sized with limited IT and cybersecurity expertise to dedicate towards protecting IT assets and personnel. The principal concern of these Organization is to keep the business operational, as they have a limited tolerance for downtime. The sensitivity of the data that they are trying to protect is low and principally surrounds

	the organization 3. Tier which are Tier 1 - Partial, Tier 2 - risk informed, Tier 3 - Repeatable and Tier 4 - Adaptive.	controls. A total of 24 controls were merged from two, three, or more security controls from the 2013 version, and 58 controls from the ISO 27002:2013 were revised to align with the current cyber security and information security environment. The Annex A control categories are 1 . Organizational control with 37 control 2. People with 8 controls 3. Physical with 14 control 4. Technological with 34 control	employee and financial information. Safeguards selected for • **IG2** (Includes IG1) An IG2 enterprise employs individuals responsible for managing and protecting IT infrastructure. These Organization support multiple departments with differing risk profiles based on job function and mission. IG2 Organization often store and process sensitive client or enterprise information and can withstand short interruptions of service • **IG3** assets and data contain sensitive information or functions that are subject to regulatory and compliance oversight. An IG3 enterprise must address availability of services and the confidentiality and integrity of sensitive data. Successful attacks can cause significant harm to the public welfare.
I ntended Aud ience	All kind of organization, either small, medium and large organization	Medium and Large organization especially those who interested	Small to medium organization

		in international certification	
• *Cost**	Low	High due to cost of certification and auditors	Low
Complexity	Moderate	High	Moderate
• *Flexibility**	Very flexible as it can be used for all kind of organization and structure	Not Flexible as there are different requirement organization must met	Flexible
• *Certification Options**	No	Yes	No

Step 2: Make Recommendations

For each of the three scenarios, recommend the most appropriate framework.

Provide a brief justification for each of your choices.

Scenarios

- **Scenario A**: A large, multinational corporation that needs a formal, internationally recognized security certification.

  Answer

  Recommended Framework: ISO 27001

  Justification: The organization is a large, mutinational corporation and it need a formal and international recognition and it is only ISO 27001 that provide global recognition and certification. ISO 27001 have a strong governance and documentation and has auditable processes that international partners can trust

- **Scenario B**: A small, non-profit organization with a very limited budget and IT staff that needs to improve its basic security hygiene.

  Answer

  Recommended Framework: CIS Control v8

Justification: The organization is a small, non-profit with very limited budget and IT staff and CIS Control v8 is a low cost, limited resources and small IT staff can handles the basic security hygiene with CIS Control v8 framework,

- Scenario C: A mid-sized technology company that wants a flexible, risk-based framework to guide its security program but does not necessarily need a certification.

Answer

Recommended Framework: NIST CSF 2.0

Justification: The organization is a mid size technology and it is flexible, risk based and that is why NIST CSF 2.0 is best approriate framework and it does not necessarily need a certification which is best for NIST CSF 2.0

References: A consolidated list of all sources you used throughout the lab.

Task 1: NIST Cybersecurity Framework (CSF) 2.0 Resources

NIST Cybersecurity Framework Official Page: https://www.nist.gov/cyberframework

NIST CSF 2.0 PDF Document: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf

CSF 2.0 Quick Start Guides: https://www.nist.gov/cyberframework/quick-start-guides

CSF 2.0 Resources Center: https://www.nist.gov/cyberframework/resources-0

CSF 2.0 Reference Tool: https://csf.tools/reference/nist-cybersecurity-framework/v2-0/

NIST CSF Implementation Guidance (CISA): https://www.cisa.gov/sites/default/files/publications/Commercial_Facilities_Sector_Cybersecurity_Framework_Implementation_Guidance_FINAL_508.pdf

Task 2: ISO 27001:2022 Control Implementation Resources

Official ISO Resources

ISO 27001 Official Page: https://www.iso.org/standard/27001

ISO Online Browsing Platform (OBP): https://www.iso.org/obp/ui/en/

ISMS.online - ISO 27001:2022 Guide for Beginners: https://www.isms.online/iso-27001/iso-27001-guide-for-beginners/

ISMS.online - Annex A Controls Explained: https://www.isms.online/iso-27001/annex-a-2022/

Advisera - ISO 27001 Annex A Controls: https://advisera.com/iso27001/annex-a-controls/

DataGuard - ISO 27001 Controls Overview: https://www.dataguard.com/iso-27001/annex-a/

ISEOBlue - Free ISO 27001 Toolkit: https://iseoblue.com/27001-getting-started/

Task 3: CIS Critical Security Controls v8 Resources

CIS Controls Official Page: https://www.cisecurity.org/controls

CIS Controls v8 Details: https://www.cisecurity.org/controls/v8

CIS Controls v8.1: https://www.cisecurity.org/controls/v8-1

CIS Controls List: https://www.cisecurity.org/controls/cis-controls-list

CIS Implementation Groups: https://www.cisecurity.org/controls/implementation-groups

CIS Controls Implementation Guide (SMEs): https://www.cisecurity.org/-/media/project/cisecurity/cisecurity/data/media/files/uploads/2017/09/CIS-Controls-Guide-for-SMEs.pdf

CIS Controls Self Assessment Tool (CSAT): https://www.cisecurity.org/cis-documentation

SANS Blog - CIS Controls v8: https://www.sans.org/blog/cis-controls-v8

Splunk - CIS Controls Guide: https://www.splunk.com/en_us/blog/learn/cis-critical-security-controls.html

Task 4: Gap Analysis Resources

NIST Gap Analysis Guidance: https://www.nist.gov/cyberframework/resources-0

ISO 27001 Gap Analysis: https://www.isms.online/iso-27001/

NIST CSF Maturity Assessment Template: https://www.reddit.com/r/cybersecurity/comments/1foz5ro/free_nist_csf_20_maturity_assessment_template/

CIS Controls Self Assessment Tool (CSAT): https://www.cisecurity.org/cis-documentation

Task 5: Framework Comparison Resources

NIST CSF vs. ISO 27001: https://www.nist.gov/cyberframework/resources-0

CIS Controls vs. NIST CSF: https://www.cisecurity.org/controls

Splunk - Framework Comparison: https://www.splunk.com/en_us/blog/learn/cis-critical-security-controls.html